

Segurança em Redes

Apresentação: Vulnerabilidade CVE-2011-2523

Felipe Kelemen, Gustavo Bastos, Octavio Carneiro

01. Descrição da Falha

Entendendo o comprometimento do vsftpd v2.3.4

Identificação da Vulnerabilidade



CVE-2011-2523

Execução remota de comandos via backdoor inserido em um ataque à cadeia de suprimentos.



Sistema Afetado

vsftpd 2.3.4. O código malicioso ficou disponível de 30/06/2011 a 03/07/2011 na plataforma de distribuição.



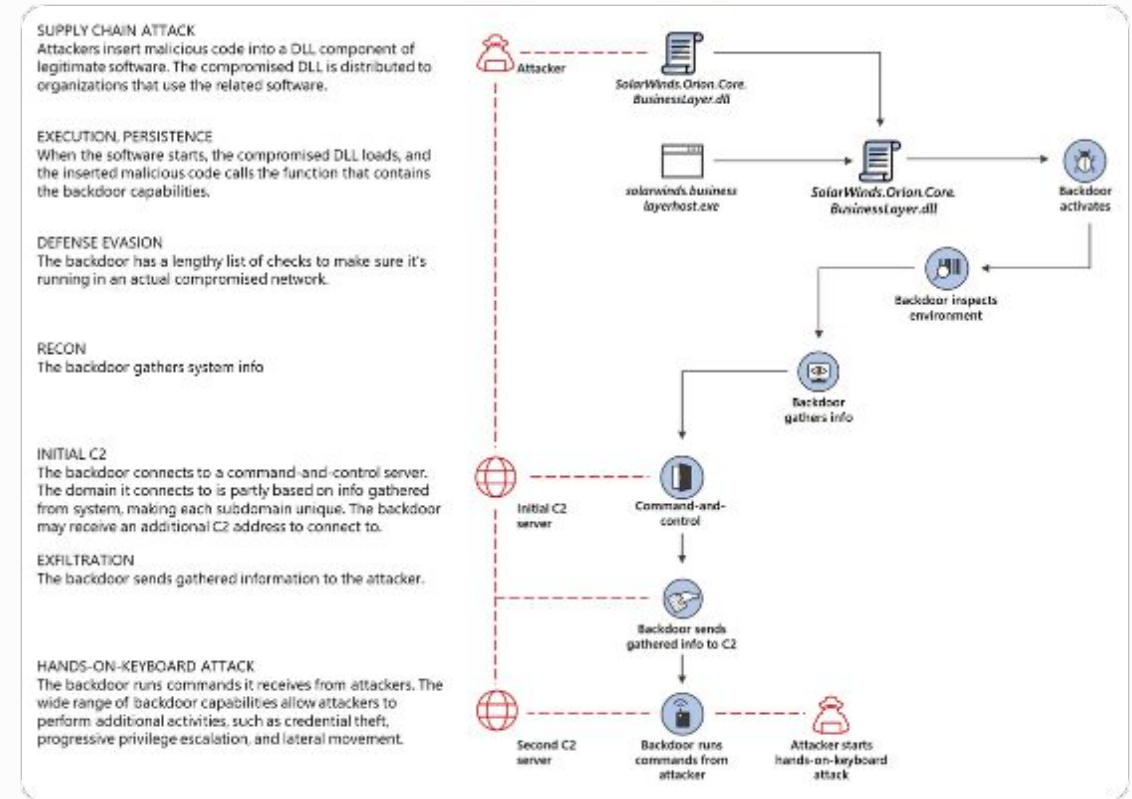
Gatilho (Trigger)

Ativado quando o nome de usuário no login contém a sequência de caracteres :)

Ataque de Supply Chain

Este caso é um exemplo clássico de comprometimento da confiança na origem:

- ✓ Código malicioso foi injetado dentro do código fonte original
- ✓ Um acesso não autorizado ao principal servidor de download permitiu a troca do código original pelo malicioso
- ✓ A versão maliciosa ficou online por **mais de 4 dias**



Funcionamento Técnico (Código)

Módulo	Função	Lógica Maliciosa
str.c	Login Handler	Verifica se o buffer contém 0x3a ':' e 0x29 ').'
sysdeputil.c	vsf_sysutil_extra()	Abre socket TCP na porta 6200 e escuta conexões.
sysdeputil.c	Shell Spawning	Executa /bin/sh com privilégios do processo vsftpd.

O redirecionamento de E/S é feito via dup2 para o socket remoto.

Severidade e Impacto

9.8

CVSS 3.X (CRITICAL)

6200

PORTA DO BACKDOOR

ROOT

PRIVILÉGIO TÍPICO

O atacante obtém um shell com os mesmos privilégios do processo que iniciou o servidor, executando comandos no contexto do daemon FTP.

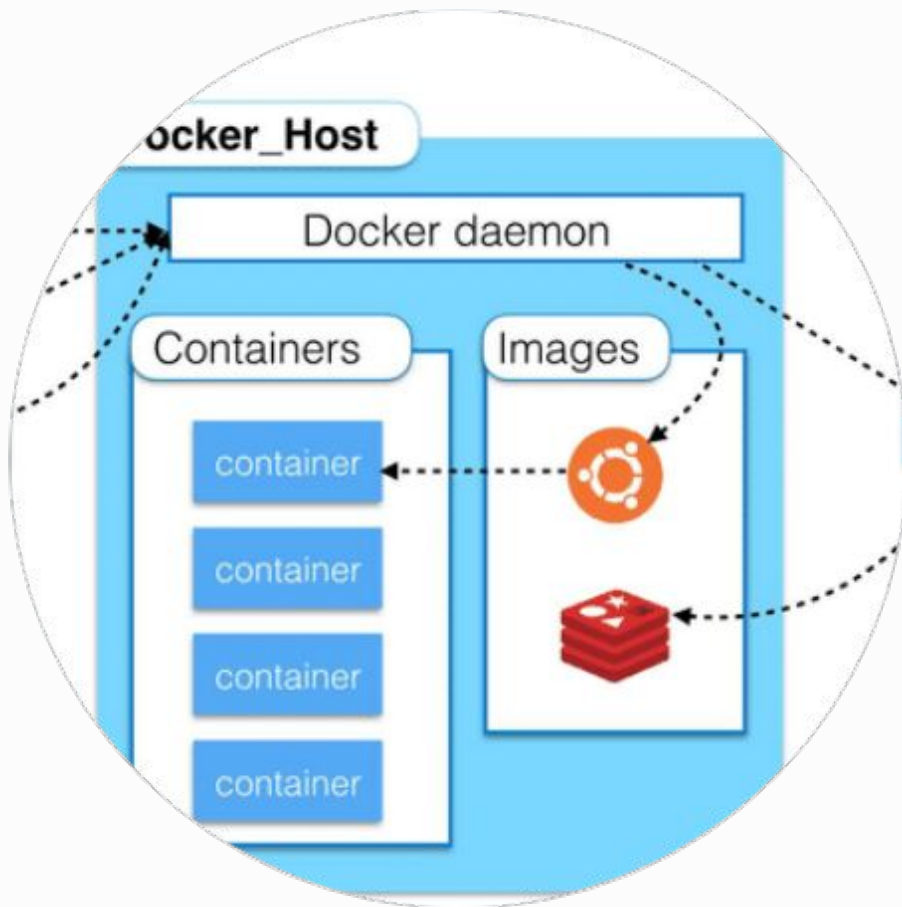
02. Experimento Prático

Metodologia de reprodução em ambiente controlado

Vídeo do Experimento

<https://www.youtube.com/watch?v=VLemKKZ67zE>

Arquitetura do Laboratório

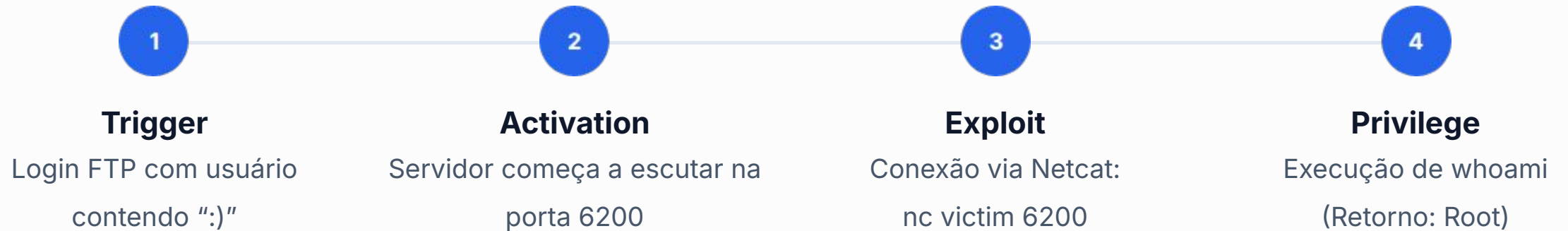


Containers Docker

Isolamento garantido por uma rede bridge dedicada (vsftpd-lab):

-  **Vítima:** Binário infectado compilado em /opt.
-  **Atacante:** Container com netcat e cliente ftp.
-  Gerenciamento via Makefile (make up, victim, attacker).

Passo a Passo da Exploração



Estratégia de Mitigação

- Exclusão dos trechos maliciosos em str.c e sysdeputil.c.
- Geração de novo binário limpo a partir do código auditado.
- Validação:** Teste de login com :) não deve mais abrir a porta 6200.



Lições Aprendidas



Integridade

Validar assinaturas e hashes de artefatos antes de qualquer instalação ou atualização de software.



Privilégios

Sempre reduzir os privilégios de serviços para limitar o impacto de um possível comprometimento.

Monitoramento

Vigiar mudanças inesperadas, como a abertura de portas não documentadas no sistema.